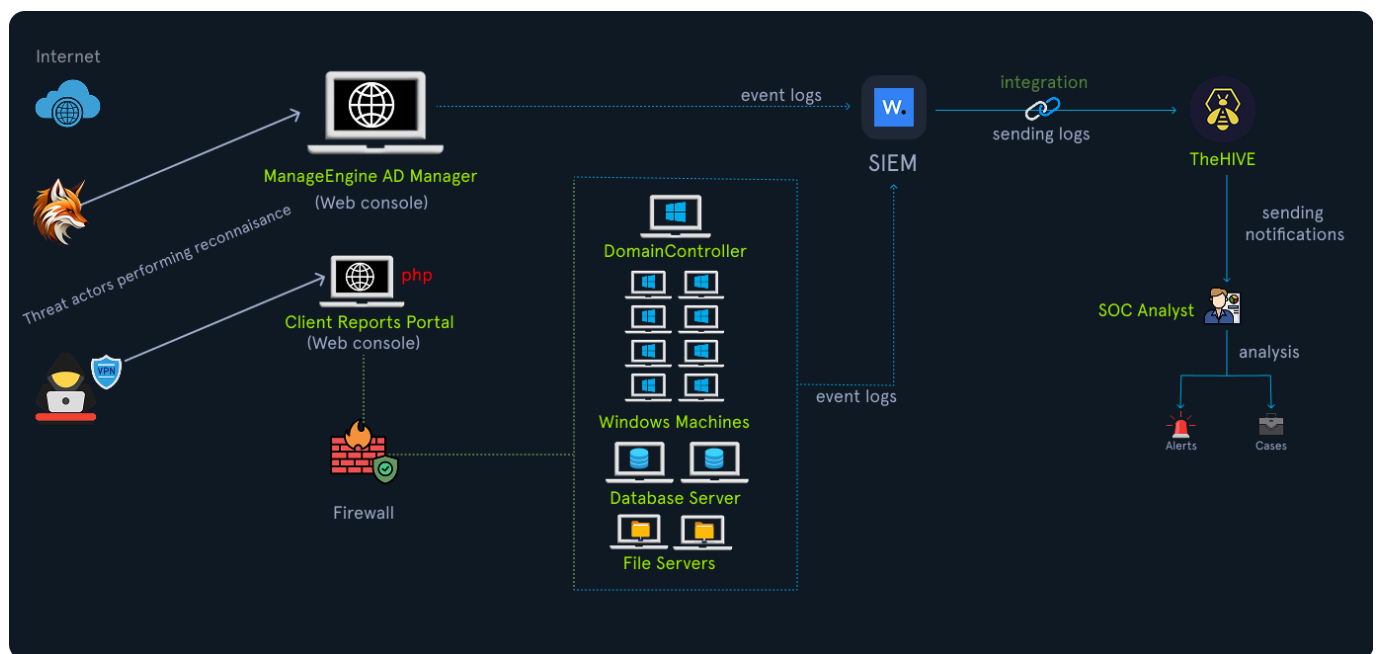


Case Study: Insight Nexus

Company Overview

Throughout this module we will use a fictional case study to help us explore some of the challenges faced by incident handlers. This study will serve to show an example of patterns observed in real-world incidents. Our company is **Insight Nexus** which is a global market research firm handling sensitive competitive data for high-profile clients in the IT sector. The firm has become the target of two distinct threat groups operating simultaneously

Network Overview



TheHive

TheHive is a case management platform for cyber security teams to handle incidents by processing alerts. Users can create cases and link multiple relevant alerts within them. The platform forms a centralised hub to manage all security alerts from various devices on a single page. TheHive offers the capability to import MITRE ATT&CK framework TTPs into its management system.

To access TheHive, go to http://TARGET_IP:9000 with the following credentials:

- Username: **htb-analyst**
- Password: **P3n#31337@LOG**

Public Internet

- External Web Application (manage.insightnexus.com): The web application ManageEngine ADManager Plus provides the capability for Active Directory management to the organization's system administrators. HTTPS (port 443) was accessible from the Internet (management portal).
- Client Reports Portal (portal.insightnexus.com): A PHP-based client reporting portal (file upload enabled for reports).

Internal environment structure

- Domain Controller: DC01.insight.local
- File Server: FS01.insight.local (file share: \fs01\projects)
- Database Server: DB01.insight.local contains sensitive databases.
- Workstations: This includes the developer fleet (ranging from DEV-001 to DEV-120), including some workstations with permissions to allow incoming RDP connections. A Windows machine with external RDP exposure was discovered during reconnaissance: DEV-021 (misconfigured).

Security

- Perimeter firewall with default logging (**no integration with Threat Intelligence**).
- Basic IDS with a high false-positive rate.
- Wazuh agents on most Windows hosts (partial coverage).
- Centralized SIEM (Wazuh) ingesting Windows Sysmon, Windows Security, web server logs, and firewall logs (limited retention).
- TheHive is used for case management, with Cortex available for enrichment.

Threat Actor 1

From the information we have gathered, the first threat actor gained entry via default credentials on the internet-facing application **ManageEngine ADManager Plus** after running an update. Leveraging this, the attackers logged in and performed reconnaissance, mapped users and machines and eventually created new privileged AD accounts. Using one of these accounts they pivoted further, identifying a misconfigured RDP service. Exploiting this entry point, they escalated control and used GPOs to deploy spyware using an MSI package.

Tactic	Technique	MITRE ID	Description
Initial Access	Exploit Public-Facing Application	T1190	Confluence CVE exploited
Execution	Command and Scripting Interpreter: PowerShell	T1059.001	PowerShell used for payload download
Persistence	Windows Service	T1543.003	Windows Service for persistence
Credential Access	LSASS Memory Dumping	T1003.001	Extracted credentials
Lateral Movement	Remote Desktop Protocol	T1021.001	RDP lateral movement
Impact	Data Encrypted for Impact	T1486	LockBit ransomware

More Information

The intrusion was first noticed by an analyst after investigating an alert relating the the creation of a file. This prompted a deeper investigation. The SOC team then realised there were two separate threat actor groups operating in their environment

- **Crimson Fox:** Primary threat actor. Suspected State-backed group specialising in credential theft and long term persistence for data exfil. A capable group known for several previous successful attacks.
- **Silent Jackal:** Secondary threat actor. A loosely organised criminal group focused on defacement and PoC intrusion. Not necessarily financially motivated and low skill.